

From Edge AI to Governed Autonomous Edge Intelligence: SGAEIA, a Security-by-Design Reference Architecture for Distributed Multi-Agent Systems

Aridio Silva
Independent Researcher, Brazil
ORCID: 0009-0008-2411-6995

September 2026

Abstract

Edge computing moved computation toward data sources, and Edge AI moved inference and learning toward devices and edge infrastructure. Generative and agentic AI extend this trajectory by moving planning, memory, tool use, delegation, and action toward the edge. The resulting transition is not only from centralized to distributed intelligence; it creates distributed authority-bearing software actors operating across heterogeneous trust domains, intermittent connectivity, and potentially cyber-physical environments. This paper presents SGAEIA (Secure Governed Autonomous Edge Intelligence Architecture), an open and vendor-neutral reference architecture and Spec-Driven Development framework for bounded, revocable, observable, and policy-mediated multi-agent Edge AI. The architecture combines non-human workload identity, capabilities and constrained delegation, criticality and autonomy classes, Agent Trust Zones, risk-adaptive authorization, external policy decision and enforcement, continuous governance-risk-compliance (GRC), evidence-as-code, formal security invariants, and security-preserving technology substitution through integration-port and adapter-conformance contracts. We further introduce an alien-cognition assurance premise: because advanced models may remain cognitively opaque and imperfectly aligned, neither model explanations nor observable reasoning may serve as authoritative safety evidence. We position these mechanisms against recent work on authenticated delegation, runtime governance, governance-first agent architectures, and emerging NIST and OWASP agent-control initiatives. The paper explicitly distinguishes designed properties, formally specified properties, locally executable evidence, and claims requiring independent or live-system validation. The accompanying public artifact provides specifications, reference code, tests, formal models, and adapter profiles; it is a research reference artifact rather than a production or safety certification.

Keywords: Edge AI; Agentic AI; Multi-Agent Systems; Zero Trust; AI Governance; Runtime Authorization; Security-by-Design; Continuous GRC; Evidence-as-Code.

1 Introduction

Edge computing emerged to reduce latency, bandwidth consumption, centralization pressure, and dependence on remote cloud connectivity [24]. Edge intelligence extended this paradigm by moving inference and training toward devices and edge infrastructure [34, 14]. Recent work further studies trustworthy Edge Intelligence, edge-efficient large language models (LLMs), federated and edge learning for LLMs, and generative AI deployment at the edge [33, 31, 22, 17].

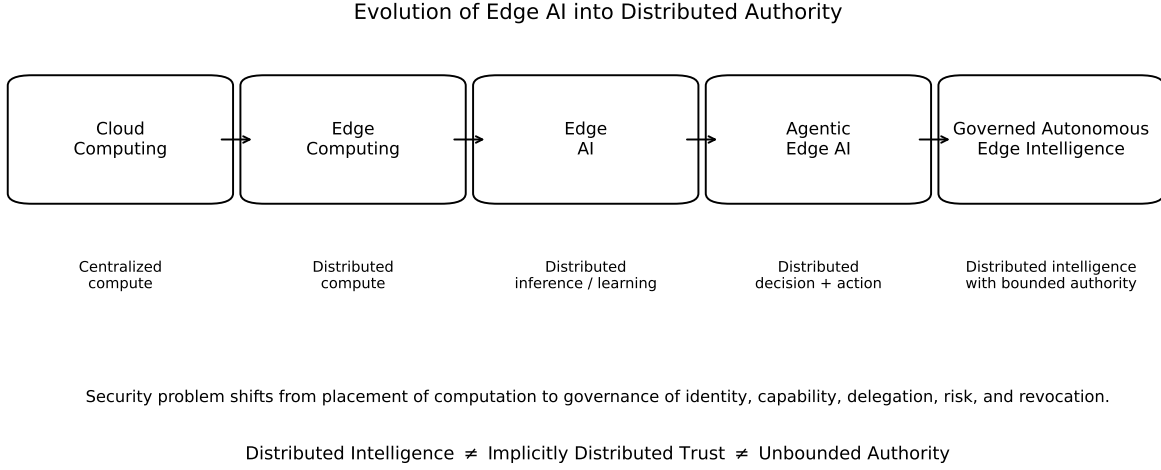


Figure 1: Conceptual evolution from centralized cloud computing to governed autonomous Edge intelligence. The security problem changes as computation evolves into distributed inference and then into authority-bearing agents capable of planning, delegation, tool use, and action. SGAEIA targets the final transition by keeping distributed authority explicitly bounded and governed.

Agentic AI changes the security problem considered here by introducing persistent, tool-using, authority-bearing actors. An agent may hold credentials, maintain state and memory, invoke tools, communicate with other agents, create sub-tasks, delegate authority, and affect systems of record or cyber-physical processes. Multi-agent collaboration expands the number of principals and interaction paths that must be governed [30, 12]. The resulting transition can be summarized as

Cloud Computing $\rightarrow$ Edge Computing $\rightarrow$ Edge AI $\rightarrow$ Agentic Edge AI $\rightarrow$ Distributed Authority.

The central security distinction is therefore

Distributed Intelligence $\neq$ Implicitly Distributed Trust $\neq$ Unbounded Authority.

This transition is already relevant beyond conceptual architecture. Capgemini’s 2026 research brief reports a survey of 1,505 executives at large organizations across 15 countries and states that 34% of respondent organizations had scaled Edge AI use cases, with additional respondents reporting limited deployments, pilots, or exploration [7]. The statistic is used here only as contextual industry evidence: the sample covers large organizations already using AI and is not treated as a population-wide estimate of global Edge AI adoption. Separately, Deloitte’s 2026 survey of 3,235 business and IT leaders across 24 countries reports that 21% of respondents described their organizations as having a mature governance model for agentic AI [11]. This result is likewise used as contextual organizational evidence rather than a universal prevalence estimate. Together, the surveys motivate, but do not establish, the architectural need for runtime governance.

Recent research already addresses important parts of this problem: authenticated delegation [25], execution-path governance [13], composite principals and capability attenuation [28], governance-first action gating [6], runtime policy enforcement for tool protocols [32], and adversarial evaluation of delegated authorization [10]. NIST has also launched an AI Agent Standards Initiative that explicitly includes agent authentication and identity infrastructure, while OWASP’s Agent Control Standard (ACS) defines runtime control hooks across agent frameworks [16, 4, 20].

Accordingly, SGAEIA does not claim priority for identity, delegation, runtime authorization, policy-as-code, or audit as isolated mechanisms. This paper contributes their composition into a vendor-neutral architecture for distributed Edge, IoT, OT, and cyber-physical agent systems, together with explicit assurance boundaries and a security-preserving technology-substitution model.

1.1 Research Questions

This paper is organized around six research questions:

- RQ1.** What additional security and governance primitives become necessary when Edge AI evolves from distributed inference and learning into distributed, tool-using, authority-bearing multi-agent systems?
- RQ2.** How can agent identity, capabilities, delegation, trust, risk, and operational criticality be composed so that effective autonomy remains explicitly bounded and revocable at runtime?
- RQ3.** How can governance requirements be transformed into externally enforced runtime controls and reconstructable evidence without making the language model itself the security authority?
- RQ4.** How can a vendor-neutral Edge AI architecture allow implementation technologies to be replaced without silently weakening security, audit, failure, and revocation semantics?
- RQ5.** Which SGAEIA properties can be established by design, formal specification, and local executable tests, and which require independent model checking, representative infrastructure, domain-specific safety validation, or live-system experiments?
- RQ6.** How should architectural assurance constrain agent authority when model representations, generalization, and observable reasoning remain incomplete or unreliable bases for safety claims?

1.2 Contributions

The paper makes six contributions. First, it formulates an authority-centric threat and trust model for agentic Edge systems in which agents are non-human principals rather than merely model endpoints. Second, it presents a governed-autonomy model that composes criticality, autonomy level, trust zone, risk, policy, and context. Third, it defines an executable governance chain from requirements and risk to policy enforcement and evidence. Fourth, it defines security-preserving vendor neutrality through Integration Port Specifications and Adapter Conformance, where API compatibility alone is insufficient. Fifth, it provides an open reference artifact with explicit assurance levels that separate design claims, formal specification, local test evidence, and independent/live validation. Sixth, it translates cognitive opacity and uncertain alignment into a conservative architectural assurance rule: uncertainty about model internals must not increase operational authority.

2 Background: From Edge Intelligence to Agentic Edge AI

Classical Edge AI focuses primarily on where models execute, how training or inference is partitioned, and how computation, communication, energy, and privacy trade-offs are optimized [34, 33]. Generative AI at the edge adds large-model inference, model compression, device-edge cooperation,

and distributed/federated adaptation [17, 31, 22]. Agentic AI adds a qualitatively different element: persistent actors that transform observations into plans and externally consequential actions.

A useful abstraction is

$$Agent = Model + State + Memory + Tools + PolicyContext + Identity.$$

When such agents are distributed across cloud, MEC, edge, IoT, and OT environments, authority itself becomes distributed. The challenge is not to prevent distributed intelligence, but to prevent authority from becoming implicit, ambient, or self-escalating. Work connecting agentic AI with emerging 6G and edge environments reinforces that multi-agent coordination and edge placement are converging research directions [1].

2.1 Alien Cognition, Generalization, and Monitoring Limits

Pachocki characterizes frontier machine intelligence as grown through large-scale optimization more than fully designed, and argues that its overall operation increasingly evades complete human description [21]. He further distinguishes goal alignment from value alignment, emphasizes the difficulty of generalization into unfamiliar or adversarial conditions, and reports diminishing confidence in chain-of-thought monitoring as reasoning becomes interleaved with tool use, communication, and non-verbal computation. The same essay anticipates a growing role for AI in its own development and argues that scaling should be constrained by confidence in alignment, monitoring, and human control.

These claims are important motivation but must be scoped carefully. *An Alien Mind* is a technical-institutional essay by an industry research leader, not peer-reviewed empirical evidence, and its forward-looking claims do not by themselves establish the behavior of a particular deployed model. This paper therefore does not infer consciousness, sentience, or inevitable deception. It adopts the narrower engineering premise that sufficiently capable models may remain partially opaque, may generalize in unanticipated ways, and may produce explanations that are incomplete or strategically unreliable.

2.2 From Model Alignment to Architectural Assurance

Model-level alignment remains necessary, but it cannot be the sole authorization boundary for consequential action. SGAEIA treats model-generated reasoning, plans, confidence statements, and explanations as non-authoritative inputs. Safety-relevant authorization is instead derived from independently administered identity, capability, delegation, policy, monitoring, approval, containment, revocation, and evidence mechanisms. The resulting assurance statement is:

When cognitive reliability cannot be demonstrated, system safety shall not depend exclusively on presumed model alignment, model-generated explanations, or observable reasoning. Agency shall remain bounded, externally mediated, auditable, containable, and revocable.

This moves the design question from whether an internal representation appears human-interpretable to whether the externally consequential action remains governable under uncertainty.

3 Related Work and Research Gap

3.1 Authenticated identity and delegation

South et al. argue that agents require authenticated and auditable delegation and show how established web identity and authorization mechanisms may be extended to agent-specific credentials and scoped authority [25]. In a concurrent 2026 preprint, Dantuluri and Sundi evaluate delegation under an untrusted-model assumption and demonstrate how compromised agents can exceed authority in common patterns unless authorization is externally confined [10]. SGAEIA adopts the same general direction—identity and delegated authority must be externally verifiable—but embeds it in an Edge-oriented architecture that also combines criticality, autonomy, trust zones, degraded-connectivity behavior, evidence, and replaceable infrastructure adapters.

3.2 Runtime governance and enforcement

In a 2026 preprint, Kaptein et al. model runtime governance as deterministic policy evaluation over partial execution paths, highlighting limitations of prompt-level controls and static authorization [13]. A concurrent 2026 preprint by Tallam proposes a five-plane architecture that combines runtime mediation, composite principals, capability attenuation, and structured audit evidence [28]. Wang et al. study runtime policy enforcement specifically for MCP-based LLM agents [32], while Zwerdling et al. study company-policy adherence in agentic workflows [35]. These works strongly support externalized policy evaluation and mediation. SGAEIA extends this line toward heterogeneous Edge/OT deployments and treats policy enforcement as one element of a larger requirement-to-evidence governance chain.

3.3 Governance-first architectures

LATTICE separates planning, execution, and governance, uses deterministic policy-as-code gates, human escalation, and cryptographic audit, and reports empirical evaluation of its reference implementation [6]. This is one of the closest architectural precedents to SGAEIA. Salient distinctions in the scope reviewed here include scope and assurance model: SGAEIA targets distributed Edge/MEC/IoT/OT and cyber-physical deployments; composes autonomy with criticality, trust, risk, and connectivity state; introduces Agent Trust Zones; and makes security-preserving component replacement an explicit architectural property. SGAEIA currently provides less live empirical evidence than LATTICE, a limitation made explicit in Section 14.

3.4 Standards and emerging control frameworks

NIST’s AI Agent Standards Initiative identifies secure agent interactions, authentication, and identity infrastructure as active standardization and research priorities [16, 4]. OWASP ACS specifies portable runtime-control hooks and emphasizes inspectability, traceability, instrumentation, and runtime behavior control across frameworks [20]. These initiatives reinforce the relevance of external controls but do not, by themselves, define the full SGAEIA architecture. In particular, SGAEIA distinguishes portability of control hooks from semantic conformance of replacement technologies.

Table 1: Author-coded qualitative comparison of representative sources inspected as of September 2026. “Partial” means the property is present only in part or under a narrower scope; “N/E” means not explicit in the inspected source and is not a claim of absence. This table is not a systematic-review claim.

Property	South	Kaptein	Tallam	LATTICE	SGAEIA
Authenticated/delegated authority	Yes	Partial	Yes	Partial	Yes
Runtime external enforcement	Partial	Yes	Yes	Yes	Yes
Path/context-sensitive governance	N/E	Yes	Yes	Partial	Yes
Edge/OT/cyber-physical scope	N/E	N/E	N/E	Partial	Yes
Criticality $\times$ autonomy model	N/E	N/E	N/E	Partial	Yes
Degraded/offline authority rule	N/E	N/E	N/E	N/E	Yes
Evidence/audit substrate	Yes	Partial	Yes	Yes	Yes
Formal security invariants	N/E	Partial	Yes	Yes	Yes
Security-preserving adapter substitution	N/E	N/E	N/E	N/E	Yes
Explicit assurance-level boundaries	N/E	N/E	Partial	Yes	Yes

4 Threat and Trust Model

The threat model includes untrusted external input, direct and indirect prompt injection, poisoned memory or retrieval, malicious or over-privileged tools, agent impersonation, credential theft and replay, delegation escalation, compromised sub-agents, autonomous lateral movement, evidence suppression, supply-chain compromise, sensor manipulation, unsafe actuation, and network/control-plane partition. It additionally considers self-affecting changes, monitor probing or disablement, apparently benign actions whose aggregate effect exceeds policy, and multiple agents composing individually permitted capabilities into prohibited collective authority. Contemporary agent-security surveys and OWASP/MITRE taxonomies reinforce the importance of these classes [9, 29, 15, 19].

The architecture assumes that the probabilistic model can be wrong, manipulated, or compromised. Consequently, a model-generated decision is never sufficient evidence of authorization. The core trust rule is:

Agent proposes; architecture authorizes or denies.

5 Formal System and Authority Model

A governed deployment is modeled as

$$S = (V, E, Z, P, I, C, R, T, L),$$

where V is the set of entities, E their relations, Z trust zones, P policies, I identities, C capabilities, R risk state, T telemetry/evidence, and L lifecycle state. Entity classes may include humans, agents, models, devices, workloads, functions, network services, and external systems.

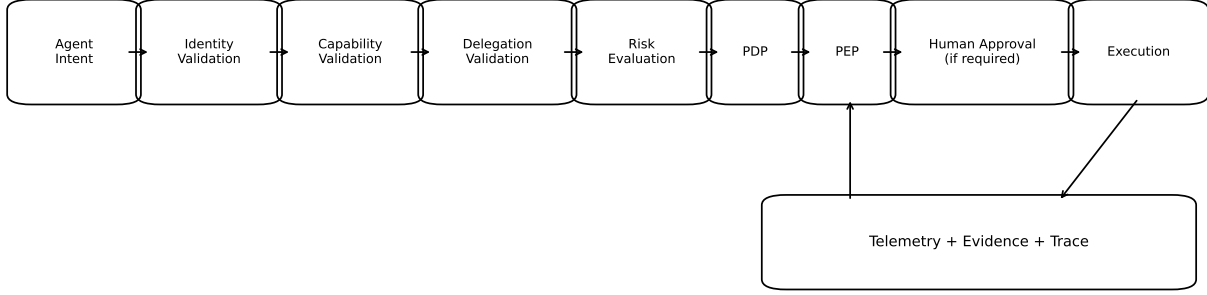
A governed agent satisfies

$$\begin{aligned} \text{Governed}(A) = & \text{Identity} \wedge \text{Owner} \wedge \text{Purpose} \wedge \text{Capabilities} \wedge \text{Policy} \wedge \text{Risk} \\ & \wedge \text{Observability} \wedge \text{Auditability} \wedge \text{Revocability}. \end{aligned}$$

We propose an effective authority envelope for agent i at time t as

$$\mathcal{A}_i(t) = f(I_i, C_i, D_i, Z_i, R_i, T_i, P_i, L_i, t),$$

SGAEIA Runtime Authorization and Evidence Path



The model proposes intent; external control points authorize, restrict, approve, deny, revoke, and preserve evidence.

Figure 2: SGAEIA runtime authorization and evidence path. Agent intent is mediated by identity, capability, delegation, risk, policy-decision, and policy-enforcement controls before execution; human approval is inserted when policy requires it. Telemetry, evidence, and trace data support reconstructability and governance without making the model the security authority.

where D_i captures delegated authority and the remaining terms capture identity, capability, trust-zone placement, risk, trust/context signals, policy, lifecycle/criticality, and time. This is an architectural abstraction rather than a fitted statistical model. A proposed SGAEIA design invariant is monotonic authority restriction:

$$Risk \uparrow \vee Trust \downarrow \vee Connectivity \downarrow \Rightarrow Authority_{effective} \nmid.$$

Thus, as a normative architecture requirement rather than an empirical causal law, degraded information or connectivity must not, by itself, increase authority.

The alien-cognition premise adds a complementary monotonic constraint:

$$CognitiveUncertainty \uparrow \Rightarrow ModelAuthority_{effective} \nmid.$$

Here, cognitive uncertainty denotes insufficient assurance about model generalization, internal strategy, or monitorability. It is not a psychological diagnosis. The constraint requires external controls to preserve or reduce authority as uncertainty rises; it does not claim that uncertainty can be represented by a single universally calibrated scalar.

6 Governed Autonomy

SGAEIA separates operational criticality L0–L4 from autonomy A0–A5. L0–L4, A0–A5, ATZ-0–ATZ-5, and the min-based effective-autonomy operator used below are SGAEIA reference-policy constructs rather than empirically calibrated universal scales. L4 denotes cyber-physical or safety-critical contexts. A5 denotes autonomous orchestration and delegation. The reference policy prohibits L4+A5. Effective autonomy is bounded by multiple constraints:

$$A_{effective} = \min(A_{configured}, A_{risk}, A_{context}, A_{trust}, A_{policy}).$$

Agent Trust Zones (ATZ-0–ATZ-5) classify operational control requirements rather than intrinsic trustworthiness. ATZ-0 represents external or unknown principals, while ATZ-5 represents cyber-physical critical environments requiring the strongest controls. ATZ-5 therefore means maximum governance requirement, not “fully trusted.”

7 Identity, Capability, and Delegation

Each governed agent is represented as a non-human identity. Workload-identity systems such as SPIFFE illustrate portable cryptographic identity mechanisms suitable for dynamic workloads [26]. Identity, however, is not authorization. A simplified authorization predicate is

$$\begin{aligned} \text{Authorize}(a, r, o, c, t) = & \text{IdentityValid}(a) \wedge \text{CapabilityValid}(a, o) \wedge \text{PolicyAllows}(a, r, o, c) \\ & \wedge \text{Risk}(a, r, o, c, t) < \text{MaxRisk} \wedge \text{Trust}(a, t) > \text{MinTrust}. \end{aligned}$$

Delegation is bounded by capability subset, depth, expiry, purpose, resource, context, and revocation semantics. A child principal cannot acquire capability outside the authority delegated by its parent.

Pairwise attenuation is insufficient when multiple agents contribute to one task graph. Collective authorization must also reject delegation cycles, prohibited capability unions, and sequences of individually low-risk actions whose cumulative effect is high impact. Likewise, an agent may not be the sole proposer, evaluator, approver, and deployer of a change affecting its own capabilities, policy, monitoring, evidence, identity, or containment boundary.

8 Zero-Trust Runtime Enforcement

The runtime path is

$$\begin{aligned} \text{Intent} \rightarrow \text{Identity} \rightarrow \text{Capability} \rightarrow \text{Delegation} \rightarrow \text{Risk} \rightarrow \text{PDP} \rightarrow \text{PEP} \\ \rightarrow \text{Approval} \rightarrow \text{Execution} \rightarrow \text{Evidence}. \end{aligned}$$

Policy Decision Points (PDPs) decide; Policy Enforcement Points (PEPs) mediate action. Human approval is inserted where risk, criticality, or policy requires it. This is consistent with zero-trust principles that reject implicit trust based on network location and emphasize dynamic, context-aware authorization and least-privilege access [23, 8].

The architecture is intentionally compatible with emerging agent-control work such as OWASP ACS, but does not require a specific agent framework. An implementation may expose framework-level control hooks while still needing independent identity, policy, risk, revocation, and evidence services.

9 Continuous GRC and Evidence-as-Code

NIST AI RMF and the Generative AI Profile provide lifecycle risk-management foundations [27, 3]. SGAEIA connects governance requirements to runtime controls through

$$\text{Regulation} \rightarrow \text{Requirement} \rightarrow \text{Risk} \rightarrow \text{Control} \rightarrow \text{Policy} \rightarrow \text{Enforcement} \rightarrow \text{Evidence}.$$

Critical actions generate correlated evidence that can include principal identity, intent, policy decision, risk score, delegation chain, tool invocation, approval, execution outcome, timestamp, and integrity metadata. Evidence-as-code does not mean that compliance is automatically established; it means that control execution produces machine-correlatable artifacts suitable for later assurance, audit, or compliance assessment.

10 Security-by-Design and Spec-Driven Development

The development chain is

$$Requirement \rightarrow Threat/Risk \rightarrow Control \rightarrow Policy \rightarrow Implementation \rightarrow Test \rightarrow Evidence.$$

Within SGAEIA, this chain is intended to operationalize Security-by-Design, Security-First, and Shift-Left/Right/Everywhere by requiring security behavior to be specified before implementation and re-evaluated at runtime. NIST secure-development guidance for generative AI provides complementary lifecycle practices [5].

11 Integration Ports and Security-Preserving Substitution

A central design goal is vendor neutrality without semantic erosion. SGAEIA therefore separates implementation technology from required port semantics. We propose the following conformance criterion as a design requirement: a replacement is conformant only when

$$\begin{aligned} ConformantReplacement = & FunctionalPass \wedge SecurityPass \wedge AuditPass \\ & \wedge FailurePass \wedge RevocationPass \wedge NoSecurityInvariantViolation. \end{aligned}$$

Integration ports cover identity, PDP, PEP, risk, registry, evidence, kill switch, observability, event bus, mesh, state, and edge orchestration. OpenAPI and AsyncAPI can express synchronous and asynchronous interface contracts [18, 2]. However, schema compatibility is only the functional layer. Security behavior under failure, revocation propagation, evidence production, and invariant preservation are separate conformance obligations.

This distinction is important in an ecosystem moving toward portable agent-control hooks [20]: portability answers whether a control can be attached; semantic conformance asks whether replacing a component preserves the required authorization, audit, failure, and revocation behavior.

12 Formalized Security Invariants

Representative invariants include

$$\begin{aligned} AgentWithoutIdentity &\Rightarrow DENY, \\ UnknownAgent &\Rightarrow DENY, \\ L4 \wedge A5 &\Rightarrow DENY, \\ DelegationDepth > MaxDepth &\Rightarrow DENY, \\ ChildCapabilities \not\subseteq ParentDelegatedCapabilities &\Rightarrow DENY, \\ PaymentCreator = PaymentApprover &\Rightarrow DENY, \\ AttestationFailed \wedge CriticalAgent &\Rightarrow STOP/QUARANTINE, \\ OfflineMode &\Rightarrow ReducedOrEqualAuthority. \end{aligned}$$

Additional design invariants prohibit self-elevation of autonomy, self-authorization by the model, and trust-boundary crossing solely on the basis of an LLM semantic decision.

The repository includes TLA+ and Alloy specifications. The properties in this section are specification-level properties: their encoding in formal-language artifacts does not by itself establish successful parsing, type checking, satisfiability analysis, or model-checker verification. This paper

does *not* claim that external TLA+ or Alloy model checkers have been executed. Selected equivalent finite-state properties are exercised by Python tests; external model-checker execution is future assurance work.

13 Reference Implementation

The public reference artifact includes Python services and models for registry, risk scoring, delegation, kill-switch behavior, evidence generation, policy decisions, service interfaces, and API exposure. It also includes OpenAPI/AsyncAPI contracts, formal specifications, deployment manifests, and adapter profiles. The architecture is intentionally replaceable: reference technologies demonstrate contracts rather than define mandatory products.

In the immutable SGAEIA v0.3.4 artifact cited in the Artifact Availability section, repository-level local validation records 31 passing tests and nine adapter profiles in the shared conformance harness. These counts describe repository-local evidence for that archived baseline and are subject to the reproducibility qualification stated below. They do not establish production security, upstream-product certification, operational resilience, safety certification, or regulatory compliance.

A separate, unreleased RC2 working candidate adds requirements SR-025–SR-035 and executable reference controls for untrusted-reasoning denial, registered and intent-bound independent monitoring, capability-gated autonomy, execution budgets, protected control-plane resources, delegation-chain validation, collective task-graph authorization, evidence chaining, and post-effect reconciliation. Its repository-local suite reports 51 passing tests together with successful specification, release-structure, and nine-profile adapter checks. These results describe the working candidate rather than the immutable v0.3.4 artifact; they are not production, cyber-range, or independent safety evidence.

For pre-submission reproducibility, the executable baseline was independently re-executed from a clean extraction: specification validation passed, the test suite reported 31 passing tests, and the adapter-conformance harness reported nine passing profiles. GitHub’s comparison from v0.3.2 to v0.3.4 reports only three changed files across citation and Zenodo-metadata commits, with no executable/test change indicated; the reproduced executable baseline is therefore unchanged for the v0.3.4 release. This reproduction does not constitute production, safety, or independent security certification.

14 Assurance Model and Current Evidence

To prevent overclaiming, SGAEIA uses four assurance levels:

- A0 — Designed.** The property is stated as an architectural requirement or design rule.
- A1 — Formally Specified.** The property is encoded in a formal-language or machine-readable specification. This level does not imply successful parsing, type checking, satisfiability analysis, or model-checker verification unless separately evidenced.
- A2 — Locally Executable/Tested.** The property is exercised by repository-local tests, contract harnesses, or executable reference logic.
- A3 — Independently/Live Validated.** The property has evidence from representative/live infrastructure, independent reproduction, external model checking, domain-specific safety validation, or equivalent independent assurance.

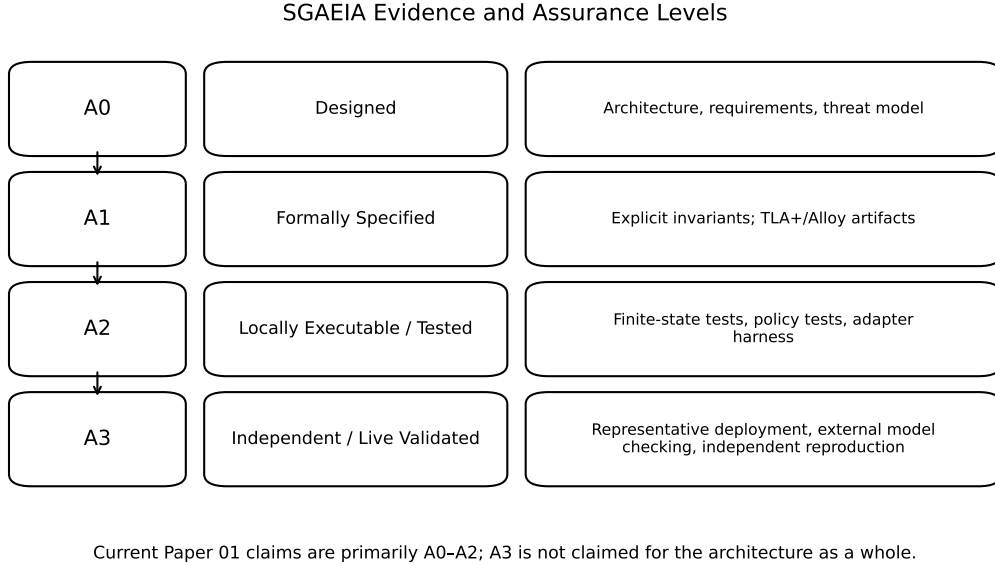


Figure 3: SGAEIA evidence and assurance levels. A0 records designed properties; A1 records formally or machine-checkably specified properties; A2 records repository-local executable or tested evidence; and A3 is reserved for independent or representative live validation. The current Paper 01 claims are primarily A0–A2.

The current public artifact primarily supports A0–A2 claims. TLA+ and Alloy artifacts support specification-level claims (A1); the Python finite-state tests and adapter harness support local executable claims (A2). A3 is not claimed for the architecture as a whole. This differs from work such as LATTICE, which already reports live and adversarial empirical evaluation of its reference implementation [6].

15 Evaluation Agenda

A full evaluation program should test at least: unauthorized-action prevention; confused-deputy and delegated-privilege escalation; token theft/replay; compromised sub-agents; policy-bypass attempts; prompt/tool injection; network and control-plane partition; degraded/offline operation; revocation propagation latency; policy evaluation overhead; evidence completeness; tamper resistance; adapter replacement under failure and revocation; sensor manipulation and unsafe actuation; collective privilege aggregation; self-affecting change; plan–tool–effect divergence; sandbagging or behavioral adaptation under perceived supervision; and independent reproduction.

Representative quantitative measures include false-allow and false-deny rates for policy enforcement, revocation propagation latency, policy-decision latency, end-to-end action overhead, evidence completeness, conformance-test coverage, and recovery behavior after partition. Cyber-physical deployments additionally require domain-specific hazard analysis and independent safety mechanisms outside the LLM decision loop.

16 Discussion

The representative literature reviewed here shows a recurring design direction around a principle that is central to SGAEIA: security-critical authorization should not depend solely on probabilistic model behavior. Authenticated delegation, runtime mediation, path-aware policy, external PEPs, and governance-first execution gates all move authority decisions outside the model [25, 13, 28, 6, 32].

The research gap addressed here is therefore architectural composition. In the representative literature reviewed here, Edge and cyber-physical systems introduce properties that enterprise cloud-agent governance does not always foreground: intermittent connectivity, local autonomy under partition, device/workload attestation, sensor/actuator exposure, heterogeneous orchestrators, constrained infrastructure, and safety-critical actuation. Conversely, in the representative Edge AI literature reviewed here, work often focuses on placement, learning, inference, efficiency, trustworthiness, and privacy without consistently treating autonomous agents as authority-bearing principals. SGAEIA joins these two problem spaces.

A distinctive design emphasis of SGAEIA is not another policy engine, but the requirement that distributed authority remain bounded across both runtime behavior and technology substitution. A component that preserves API shape but weakens revocation, failure mode, evidence, or invariant enforcement is not a conformant replacement even if functionality appears equivalent. The alien-cognition framing strengthens this argument without replacing model-alignment research: model alignment concerns what the model tends to pursue, while architectural assurance constrains what the deployed system can actually authorize, execute, conceal, or make irreversible.

17 Limitations and Threats to Validity

SGAEIA is a research reference architecture, not a certified product. Several limitations follow. First, risk thresholds and autonomy mappings are reference policies rather than empirically optimized universal constants. Second, the architecture’s threat model may be incomplete as agent protocols and attack techniques evolve. Third, formal specifications do not establish correctness unless the relevant tools and assumptions are actually exercised and reviewed. Fourth, local tests do not reproduce the complexity of production multi-agent, network, hardware, or OT environments. Fifth, the related-work comparison is scoped to representative sources and uses “not explicit” rather than inferred absence; it is not a systematic-review claim. Sixth, adoption statistics are drawn from industry surveys with non-random organizational sampling and are used only as contextual motivation. Seventh, the alien-cognition premise is motivated partly by a technical-institutional essay rather than peer-reviewed evidence; it is used as a conservative engineering assumption, not proof of inevitable recursive self-improvement, deception, consciousness, or model behavior. Finally, safety-critical use requires domain-specific safety engineering, independent interlocks, hazard analysis, and certification processes beyond this architecture.

18 Conclusion

Edge computing created distributed computation, Edge AI created distributed intelligence, and agentic Edge AI introduces distributed agency and authority. Recent research and emerging standards increasingly emphasize authenticated delegation, runtime mediation, external policy enforcement, and agent identity as important controls. SGAEIA builds on this direction and contributes an integrated reference architecture for distributed Edge/MEC/IoT/OT settings in which autonomy is bounded by identity, capability, delegation, trust, risk, policy, criticality, and

context; governance produces reconstructable evidence; and technology substitution is permitted only when security semantics are preserved. Because capable models may remain cognitively opaque and imperfectly monitorable, the architecture does not treat an explanation of intended behavior as equivalent to permission for consequential action.

The central design principle is simple: intelligence may be distributed and cognitively unfamiliar; authority must remain explicitly governed.

Artifact Availability

The canonical living source is available at <https://github.com/aridiosilva/SGAEIA>. The SGAEIA project Concept DOI is 10.5281/zenodo.22557795. The immutable SGAEIA v0.3.4 research artifact used as the current citation baseline is archived at Zenodo under Version DOI 10.5281/zenodo.22557796. The repository is licensed under Apache-2.0. The artifact is provided as a research reference architecture and demonstrative implementation, not as production, safety, security, or regulatory certification.

References

- [1] Laha Ale, Scott A. King, Ning Zhang, and Huanlai Xing. Enhancing generative AI reliability via agentic AI in 6G-enabled edge computing. *Nature Reviews Electrical Engineering*, 2:441–443, 2025. Comment; published 14 April 2025.
- [2] AsyncAPI Initiative. Asyncapi specification version 3.1.0, January 2026.
- [3] Chloe Autio, Reva Schwartz, Jesse Dunietz, Shomik Jain, Martin Stanley, Elham Tabassi, Patrick Hall, and Kamie Roberts. Artificial intelligence risk management framework: Generative artificial intelligence profile. Technical Report AI 600-1, National Institute of Standards and Technology, 2024.
- [4] Harold Booth, William Fisher, Ryan Galluzzo, and Joshua Roberts. Accelerating the adoption of software and artificial intelligence agent identity and authorization. NIST NCCoE Concept Paper, Initial Public Draft, 2026.
- [5] Harold Booth, Murugiah Souppaya, Apostol Vassilev, Michael Ogata, Martin Stanley, and Karen Scarfone. Secure software development practices for generative AI and dual-use foundation models: An SSDF community profile. Technical Report SP 800-218A, National Institute of Standards and Technology, 2024.
- [6] Elias Calboreanu. LATTICE: a governance-first architecture for authorized autonomous AI operations. *Frontiers in Artificial Intelligence*, 9:1800407, 2026.
- [7] Capgemini Research Institute. The multi-year ai advantage: Building the enterprise of tomorrow. Technical report, Capgemini Research Institute, 2026. Survey of 1,505 executives at organizations with more than USD 1 billion in annual revenue across 15 countries; fieldwork November 2025.
- [8] Ramaswamy Chandramouli and Zack Butcher. A zero trust architecture model for access control in cloud-native applications in multi-cloud environments. Technical Report SP 800-207A, National Institute of Standards and Technology, 2023.

- [9] Anshuman Chhabra, Shrestha Datta, Shahriar Kabir Nahin, and Prasant Mohapatra. Agentic AI security: Threats, defenses, evaluation, and open challenges. *IEEE Access*, 14:49455–49482, 2026. Version of record published March 2026; preprint: arXiv:2510.23883.
- [10] Panduranga Sai Varma Dantuluri and Jyotirmoy Sundi. Delegation without trust: An empirical gap analysis of identity, authorization, and runtime governance in multi-agent LLM systems, 2026. Concurrent preprint; submitted 31 August 2026.
- [11] Deloitte AI Institute. The state of ai in the enterprise. Technical report, Deloitte, 2026. Survey of 3,235 business and IT leaders across 24 countries; fieldwork August–September 2025.
- [12] Lewis Hammond, Alan Chan, Jesse Clifton, Jason Hoelscher-Obermaier, Akbir Khan, Euan McLean, Chandler Smith, Wolfram Barfuss, Jakob Foerster, et al. Multi-agent risks from advanced AI, 2025.
- [13] Maurits Kaptein, Vassilis-Javed Khan, and Andriy Podstavnychy. Runtime governance for AI agents: Policies on paths, 2026.
- [14] En Li, Zhi Zhou, and Xu Chen. Edge intelligence: On-demand deep learning model co-inference with device-edge synergy. In *Proceedings of the 2018 Workshop on Mobile Edge Communications*, pages 31–36, 2018.
- [15] MITRE. ATLAS: Adversarial threat landscape for artificial-intelligence systems, 2026. Accessed September 2026.
- [16] National Institute of Standards and Technology. AI agent standards initiative. NIST, 2026. Created 17 February 2026; updated 14 August 2026.
- [17] Mozghan Navardi, Romina Aalishah, Yuzhe Fu, Yueqian Lin, Hai Li, Yiran Chen, and Tinoosh Mohsenin. GenAI at the edge: Comprehensive survey on empowering edge devices. *Proceedings of the AAAI Symposium Series*, 5(1):180–187, 2025.
- [18] OpenAPI Initiative. Openapi specification version 3.2.0, September 2025.
- [19] OWASP GenAI Security Project. OWASP top 10 for agentic applications for 2026, December 2025. Publication title refers to the 2026 edition; published 9 December 2025.
- [20] OWASP GenAI Security Project. Agent control standard (ACS), September 2026.
- [21] Jakub Pachocki. An alien mind, September 2026. Technical-institutional essay; accessed September 8, 2026.
- [22] Francesco Piccialli, Diletta Chiaro, Pian Qi, Valerio Bellandi, and Ernesto Damiani. Federated and edge learning for large language models. *Information Fusion*, 117:102840, 2025.
- [23] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. Zero trust architecture. Technical Report SP 800-207, National Institute of Standards and Technology, 2020.
- [24] Weisong Shi, Jie Cao, Quan Zhang, Youhuizi Li, and Lanyu Xu. Edge computing: Vision and challenges. *IEEE Internet of Things Journal*, 3(5):637–646, 2016.
- [25] Tobin South, Samuele Marro, Thomas Hardjono, Robert Mahari, Cedric Deslandes Whitney, Alan Chan, and Alex Pentland. Position: AI agents need authenticated delegation. In *Proceedings of the 42nd International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pages 82211–82231. PMLR, 2025.

- [26] SPIFFE Project. The SPIFFE standard, 2026. Accessed September 2026.
- [27] Elham Tabassi. Artificial intelligence risk management framework (AI RMF 1.0). Technical Report AI 100-1, National Institute of Standards and Technology, 2023.
- [28] Krti Tallam. A five-plane reference architecture for runtime governance of production AI agents, 2026.
- [29] Yaxin Tang, Yijia Liu, Jiahe Lan, Zheng Yan, and Erol Gelenbe. Security of LLM-based agents regarding attacks, defenses, and applications: A comprehensive survey. *Information Fusion*, 127:103941, 2026.
- [30] Khanh-Tung Tran, Dung Dao, Minh-Duong Nguyen, Quoc-Viet Pham, Barry O’Sullivan, and Hoang D. Nguyen. Multi-agent collaboration mechanisms: A survey of LLMs, 2025.
- [31] Rui Wang, Zhiyong Gao, Liuyang Zhang, Shuaibing Yue, and Ziyi Gao. Empowering large language models to edge intelligence: A survey of edge efficient LLMs and techniques. *Computer Science Review*, 57:100755, 2025.
- [32] Shanshan Wang, Sizheng Zhu, and Rende Li. Runtime policy enforcement for MCP-based LLM agents. *Electronics*, 15(13):2829, 2026.
- [33] Xiaojie Wang, Beibei Wang, Yu Wu, Zhaolong Ning, Song Guo, and Fei Richard Yu. A survey on trustworthy edge intelligence: From security and reliability to transparency and sustainability. *IEEE Communications Surveys & Tutorials*, 27(3):1729–1757, 2025.
- [34] Zhi Zhou, Xu Chen, En Li, Liekang Zeng, Ke Luo, and Junshan Zhang. Edge intelligence: Paving the last mile of artificial intelligence with edge computing. *Proceedings of the IEEE*, 107(8):1738–1762, 2019.
- [35] Naama Zwerdling, David Boaz, Ella Rabinovich, Guy Uziel, David Amid, and Ateret Anaby-Tavor. Towards enforcing company policy adherence in agentic workflows. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing: Industry Track*, pages 595–606. Association for Computational Linguistics, 2025.